

Identify Attackers (CY004)

One of the most important steps in threat modelling is understanding not just what could go wrong, but who might make it go wrong. An attacker is not an abstract concept they are a real person or group with specific motivations, capabilities, and methods. Identifying who is likely to target Phoenix, why they would do so, and how they operate is what allows the team to design defences that are proportionate, targeted, and genuinely effective.

Phoenix sits at the intersection of two environments that attract very different kinds of attackers natural disaster response and digital infrastructure. Some attackers see disaster-affected communities as easy financial targets. Others are technically sophisticated and have their sights set on the system's infrastructure itself. Six attacker profiles have been identified as relevant to Phoenix.

Attacker 1 → Opportunistic Cybercriminals

Who They Are: These are financially motivated individuals or loosely organised groups who moves very fast to exploit the chaos that comes with a disaster. They does not really need to break into any systems, what they need is vulnerable people, and disasters very reliably produces them.

Motivation: Their motivation is purely financial gain. When a disaster strikes, people are frightened, distracted and are actively looking for any kind of assistance they can get. Opportunistic cybercriminals takes advantage of that window by using scams, fake charity websites and fraudulent SMS campaigns to target these vulnerable people. During the 2019-20 Black Summer bushfires, over 500 of such scams was documented by Scamwatch alone, which shows just how big of a problem this really is (Scamwatch, 2020).

Capabilities: Their capabilities is moderate. They uses off-the-shelf tools and pre-built scam templates that is rapidly customised to reference the specific disaster that is happening. Speed is their biggest advantage because they moves faster than public awareness and faster than what most monitoring systems can actually respond to.

How They Target Phoenix: They is most relevant to Entry Point 2 which is the External Cyber Threat and Scam Intelligence Feeds. By generating very high volumes of scam content, they creates the kind of threat signals that Phoenix is designed to detect. Their indirect threat comes through evasion, because if the content is crafted in a way that slips past the AI model's detection, Phoenix's effectiveness gets reduced without there even being any direct attack on it's infrastructure. They may also submit false reports through Entry Point 4 which is the Community Feedback Module, just to confuse the system (Scamwatch, 2020; Australian Taxation Office, 2020).

Attacker 2 → State-Sponsored Advanced Persistent Threat (APT)

Actors

Who They Are: These are highly skilled and very well-resourced threat groups that operates almost like professional intelligence services. They never rushes into anything, instead they takes their time to plan very carefully, wait patiently, and then strikes at the moment where it will cause the greatest impact possible.

Motivation: Their motivation is mainly strategic and political. A nation-state adversary that is targeting Phoenix during an active disaster is not after money at all, they are after disruption, intelligence and influence. If they manages to suppress official emergency alerts or compromise DMT personnel during a major disaster, it would not just harm the communities but it would also seriously damage the public confidence in the government institutions that is suppose to be protecting them in the first place.

Capabilities: Their capabilities is very high. APT actors have access to zero-day vulnerabilities, custom malware and plenty of resources for long-term reconnaissance. They are very patient, precise and are extremely good at covering their tracks so that they dont get caught or detected easily by anyone.

How They Target Phoenix: They are most likely to target Trust Boundary 4 which is the DMT Login, through spear-phishing, credential harvesting or supply-chain attacks. They may also go after Entry Point 1 which is the disaster data APIs, to manipulate the contextual intelligence that is driving Phoenix's threat elevation. On top of that they might also target Entry Point 6 which is the Alert System, to suppress or falsify the official emergency communications (Azambuja et al., 2023; Chakraborty et al., 2024).

Attacker 3 → Hacktivists

Who They Are: These are individuals or groups who uses cyber attacks as a form of political protest. They are not motivated by money or profit at all, instead they are driven by their own beliefs and they are very willing to disrupt any systems that they associate with causes they oppose.

Motivation: Their motivation is mostly ideological. A hacktivist group may target Phoenix just to make a public statement about government disaster response, AI in public safety, or emergency management decisions that they personally disagree with. The disruption that they create can cause very real harm, especially if it interferes with the alert delivery system during an active disaster where people actually needs help.

Capabilities: Their capabilities is quite variable and can range from just individuals who are using freely available tools, all the way to well-organised collectives that is capable of carrying out coordinated denial-of-service attacks and public data leaks. So they should not be underestimated at all.

How They Target Phoenix: They is most likely to target Entry Point 3 which is the DMT User Login, through credential attacks. They may also go after Entry Point 6 which is the Alert System API endpoints, through denial-of-service attacks that is designed to disrupt the alert delivery at very high-profile moments. On top of that they may also attempt to leak DMT review data publicly just to embarrass the organisations that is responsible for Phoenix (Azambuja et al., 2023).

Attacker 4 → Insider Threats

Who They Are: These are perhaps the most uncomfortable type of attacker to acknowledge, because they are not outsiders at all. They are people who already have legitimate access to Phoenix, such as DMT staff, system administrators, government analysts or contractors. They are dangerous precisely

because they operate from within the system's own trust boundaries, which make them very hard to detect.

Motivation: Their motivation is quite variable. A malicious insider may be motivated by financial incentives, personal grievances, ideological alignment with an external threat actor, or even coercion. On the other hand a negligent insider causes harm not through any bad intention but simply through carelessness, like clicking on a phishing link, reusing passwords, or misconfiguring system settings without even realising the consequences of what they do.

Capabilities: Their capabilities are very high by default. Because insiders already hold authenticated access, they do not need to overcome any external security controls at all. A malicious insider that has Administrator privileges could suppress alerts, alter model configurations, or introduce corrupted feedback into the retraining pipeline with very minimal technical effort, which makes them extremely dangerous.

How They Target Phoenix: Insider threats exploit Trust Boundary 4, not by breaking through it but by simply operating legitimately within it. The risk is mostly concentrated in the system's most sensitive functions such as alert approval, model configuration and data source management. They are also very relevant to Trust Boundary 2, where a malicious insider could directly introduce corrupted records into the Scam DB or Cyber Threat DB (Spyros et al., 2025; Azambuja et al., 2023).

Attacker 5 → Organised Cybercrime Groups

Who They Are: Unlike opportunistic cybercriminals, organised groups are much more methodical, technically sophisticated, and are capable of carrying out sustained and coordinated attacks against very specific targets. They approach their targets with the same kind of planning and professionalism that legitimate organisations would bring to complex projects, except that their main objective is extortion.

Motivation: Their motivation is financial gain at a very large scale. They see emergency services and disaster management infrastructure as very high-value targets, because these are systems that simply cannot afford to have any downtime and may therefore be more willing to pay ransoms when they are put under pressure. The December 2022 ransomware attack on Fire Rescue Victoria is a very well documented example of this type of attacker successfully targeting Australian emergency services (Chirgwin, 2023).

Capabilities: Their capabilities are very high. They have access to sophisticated ransomware tools, botnets and professional phishing infrastructure. They conduct very thorough reconnaissance, identify specific vulnerabilities, and then execute their attacks with a lot of precision so that they can cause maximum damage.

How They Target Phoenix: They are most likely to deploy ransomware against Phoenix's core infrastructure, which could include encrypting databases, disrupting stream processing, or taking down the alert system during an active disaster when the pressure to restore service is at its highest. Their primary access vectors are spear-phishing against DMT staff and exploitation of vulnerabilities in stream processing or database infrastructure, which mostly targets the Trust Boundaries 2 and 4 (Chirgwin, 2023; Azambuja et al., 2023).

Attacker 6 → Misinformation Actors

Who They Are: These are individuals, groups, or state-aligned entities who deliberately create and

spreads false information during disaster events. Their main goal is to cause confusion, erode public trust and interfere with emergency response. What makes them different is that they do not typically attack systems directly, instead they go after the information environment that Phoenix is trying to protect.

Motivation: Their motivation can vary quite a lot. It can range from financial gain through viral content monetisation, to political objectives like undermining the public confidence in government institutions, or even just to deliberately cause harm by getting in the way of disaster response efforts. A very real example of this is the 2019-20 Black Summer bushfires, where deliberate misinformation campaigns directly complicated public safety communication and added even more pressure on emergency services that was already overwhelmed (Nguyen & Bogle, 2020).

Capabilities: Their capabilities are somewhere between moderate to high and it is growing very rapidly. The rise of AI-generated images, videos and text has made it so much easier to create very convincing false content at a large scale. This is something that is happening faster than what many existing detection frameworks can keep up with, which makes it a very serious and growing threat (Hunt et al., 2022; Vicari & Komendatova, 2023).

How They Target Phoenix: They target Phoenix indirectly through Entry Point 2 by flooding social media platforms with false content that the system then has to process and classify. If they are sophisticated enough to get past the AI detection, Phoenix's ability to flag genuine misinformation becomes degraded without there even being any direct attack. They may also go after Entry Point 4 which is the Community Feedback Module, by sending coordinated false submissions that are slowly designed to shift the AI model's classifications over a period of time (Hunt et al., 2022; Vicari & Komendatova, 2023).

Summary of Attacker Profiles

Attacker	Motivation	Capability	Primary Target in Phoenix
Opportunistic Cybercriminals	Financial gain	Moderate	Entry Points 2 and 4
State-Sponsored APT Actors	Strategic / political	Very high	Trust Boundary 4
Hacktivists	Ideological	Variable	Entry Points 3 and 6
Insider Threats	Variable	High by default	Trust Boundaries 2 and 4
Organised Cybercrime Groups	Financial gain at scale	High	Trust Boundaries 2 and 4
Misinformation Actors	Variable	Moderate to high	Entry Points 2 and 4

Why Identifying Attackers Matters for Phoenix

Every security control in Phoenix traces back to a specific attacker. Data Validation exists because of opportunistic cybercriminals and misinformation actors. Multi-factor authentication exists because of APT actors and organised cybercrime groups. The Discard if Irrelevant filter exists because of misinformation actors corrupting the feedback pipeline. Anomalous login detection exists because of insider threats and APT infiltration. The immutable audit log exists because every attacker, once detected, must leave a traceable record.

Phoenix does not face a single uniform threat — it faces a diverse and evolving adversary landscape. Recognising that diversity and designing defences that address each attacker type specifically is what transforms Phoenix from a system that merely functions into one that communities, emergency services, and government agencies can genuinely trust (Azambuja et al., 2023; Chakraborty et al., 2024).

Complete Attack List for Phoenix Cyber Threat Detection System

CATEGORY 1 → EXTERNAL DATA FEED ATTACKS (ENTRY POINTS 1 & 2)

1. API Key Compromise Think of an API key like a house key, its basically what the system uses to get into external data sources like BoM or Scamwatch. Now if somebody gets hold of that key, whether its through a dodgy phishing email or someone on the inside who shouldnt be trusted, they can basically walk right in and do whatever they want. They could send through fake requests, tamper with the data Phoenix is receiving, or even just pretend to be a completely legit data source and nobody would know the difference.

2. Man-in-the-Middle (MitM) Attack So imagine Phoenix is trying to have a private conversation with an external data provider, but theres someone secretly sitting in the middle of that conversation without either side knowing. That is basically what this attack is. The attacker can just read everything, change things around, and pass it along like nothing happened. So Phoenix might end up getting disaster data that has been quietly altered to make it think a threat is happening somewhere when it actually isnt, or the other way around.

3. DNS Spoofing This one is a bit like changing the road signs so someone ends up at the completely wrong destination. The attacker messes around with the DNS system so that whenever Phoenix tries to reach out to BoM or Scamwatch, it actually gets quietly redirected to a fake server that the attacker controls. Phoenix has absolutely no idea this is happening, it just keeps on thinking its talking to the real thing the whole time.

4. Denial-of-Service (DoS) Attack Against Data Provider Endpoints This is pretty simple really. The attacker just keeps hammering a data providers endpoints with so many requests that the whole thing eventually falls over and goes offline. For Phoenix that is a really serious problem because it means the disaster and threat feeds it relies on just stops coming through. And the worst part is this tends to happen at exactly the moments when Phoenix needs that information the most.

5. Distributed Denial-of-Service (DDoS) Attack Same idea as a DoS but the attacker does not just use one machine, they uses thousands of hacked computers all firing at the same time from different locations all around the world. That makes it incredibly difficult to block because you cannot just block one IP address and call it done. If something like this hits Phoenix's ingestion endpoints it could just completely knock the entire detection pipeline offline.

6. Feed Replay Attack This one is a bit clever really. The attacker records a legitimate data feed response from some point in the past and then just plays it back again later as if it is fresh and current. Phoenix then starts making decisions based on that old outdated information, which is a real problem because the actual situation on the ground could have changed completely since then.

7. SSL/TLS Certificate Spoofing Certificates is basically Phoenix's way of checking that the server it is trying to connect to is actually who it says it is. If an attacker can fake one of these certificates convincingly enough, they can pretend to be a trusted server and just start sending Phoenix whatever false information they want. And the whole time Phoenix just thinks it is having a perfectly safe and legitimate conversation.

8. Supply-Chain Attack on a Trusted Data Provider What makes this one particularly sneaky is that the attacker does not go after Phoenix at all. Instead they target one of the organisations that Phoenix already trusts and gets its data from, like a government API provider. Because the bad data is genuinely coming from a source Phoenix already trusts, it sails straight through all the validation checks without raising any red flags whatsoever.

9. Data Poisoning Through False Scam Report Submissions So the attacker starts flooding platforms like Scamwatch with heaps of fake scam reports that look believable enough to pass as real. Over time this slowly warps the AI model's understanding of what an actual scam looks like. Eventually the model might start flagging totally innocent things as threats, or worse it might start letting real scams slide through without catching them.

10. Adversarial Content Crafted to Evade AI Detection This is where someone puts serious effort into crafting content, like fake posts or scam messages, that is specifically built to fly under Phoenix's radar without getting flagged. The clever thing is they do not even need to get inside the model to work this out. They can just keep testing different things, see what gets caught and what does not, and eventually figure out what slips through.

11. API Rate-Limiting Attack The attacker just bombards the APIs with requests until Phoenix gets temporarily cut off from accessing them. While Phoenix is locked out it cannot properly keep an eye on things, and during that window real threats could quite easily slip through without anyone noticing them at all.

12. Deliberate Threat Indicator Flooding This one is not really about sneaking in specific false data, its more about just burying the analysts in so much noise that they cannot cope. The attacker sends through massive volumes of fake high priority alerts so that the DMT analysts end up completely overwhelmed and starts missing the actual real threats that are buried somewhere in all that mess.

13. Schema Manipulation Attack This involves sending data that is structured in a weird or broken way that Phoenix simply is not expecting. If this ends up breaking the Data Validation component without anyone realising it, that broken data just keeps flowing through the rest of the pipeline and can cause all kinds of unpredictable chaos in the parts of the system that comes after it.

14. Timestamp Manipulation The attacker fiddles with the dates and times on incoming data to make old reports look brand new, or to make recent threats look like old news. This really throws off the Correlation Engine because it depends heavily on timing to work out whether a threat is actually connected to whatever disaster is currently happening right now.

15. Geolocation Spoofing This is where the location data attached to threat reports or scam activity gets faked to show a completely different area than where it is actually coming from. By doing this the attacker stops Phoenix from being able to properly link the activity to the disaster it was actually designed around targeting, which makes the whole detection a lot less useful.

16. Coordinated Bot Campaign The attacker basically lets loose a massive army of fake bot accounts across social media platforms and gets them all flooding things with fake disaster related content at the exact same time. The sheer scale and coordination of it is the whole point because it just

completely buries Phoenix's preprocessing and AI layers in noise and makes the whole detection system far less reliable.

CATEGORY 2 → AUTHENTICATION AND ACCESS ATTACKS (ENTRY POINTS 3 & TRUST BOUNDARY 4)

17. Brute Force Attack This is probably the most straightforward attack on the whole list. The attacker just keeps guessing passwords one after another until they eventually lands on the right one. If the system does not have something in place to lock accounts after a few wrong attempts, the attacker can just keep going for as long as it takes, especially if the password is something short or obvious.

18. Credential Stuffing The attacker grabs a big list of usernames and passwords that was leaked from some other website or app and just tries them all on the Phoenix login. Because so many people use the exact same password for everything, this works way more often than you would expect, even on systems that have never actually been compromised themselves.

19. Spear-Phishing Against DMT Personnel This one is really personal. The attacker does proper research on specific DMT staff members, digs up details about them from public sources, and then puts together a message that feels genuinely believable and urgent. When someone is already stressed and under pressure during an active disaster, this kind of targeted message is incredibly hard to see through.

20. General Phishing Campaign This is the less targeted version where the attacker just fires out a suspicious email to as many DMT staff as they can at once, usually dressed up to look like it came from IT support or some government body. Its not nearly as precise as spear-phishing but if you send it to enough people, someone is almost certainly going to fall for it.

21. Session Hijacking When a DMT user logs in the system gives them a session token to keep track of who they are. If an attacker manages to get hold of that token somehow, they can just use it to walk straight into the system pretending to be that person, with all their access and privileges, and without ever needing to know the password.

22. Session Fixation This one works a bit differently. Rather than stealing a token after someone has logged in, the attacker sets up a token themselves beforehand and tricks the user into authenticating with that specific token. Once the user has logged in with it, the attacker already knows what it is and can use it to access the whole session.

23. Cross-Site Request Forgery (CSRF) This is where an attacker tricks a DMT user who is already logged in into accidentally doing something harmful inside Phoenix without even realising it. Maybe they clicks on a link somewhere outside the system and that link secretly sends a request to Phoenix in the background, like changing a setting or approving something dodgy, and Phoenix just assumes it is legitimate because the user is already logged in.

24. Cross-Site Scripting (XSS) This is where malicious code gets injected into Phoenix's web interface and then runs automatically in the browser of whoever opens that particular page. It can steal login cookies, send users off to fake login pages, or silently change what appears on their screen without them having even the slightest clue something is wrong.

25. Multi-Factor Authentication Bypass via SIM Swapping Even with MFA turned on this attack can get around it. The attacker contacts the phone carrier and convinces them to move a DMT staff

member's number onto a SIM card that the attacker controls. From that point they can intercept all the one-time codes getting sent through by SMS and use them to log straight in.

26. OAuth Token Theft via Open Redirect If Phoenix uses OAuth for authentication and there is a redirect vulnerability hiding somewhere in the system, an attacker can set up a dodgy link that tricks the authentication server into sending the user's access token directly to the attacker rather than back to the actual application where it is supposed to go.

27. Password Reset Abuse This is about taking advantage of weak or sloppy account recovery setups, things like security questions that anyone could guess, or reset links that just never expire. By exploiting these gaps the attacker can get access to a DMT account without ever needing to know the actual password that belongs to it.

28. Account Takeover via Compromised Personal Email If a staff member's personal email gets hacked, the attacker can use it to kick off a password reset on their Phoenix work account. This completely sidesteps all the organisation's own security controls because the reset just goes straight to a personal inbox that the attacker is now sitting inside.

29. Privilege Escalation This is where an attacker who only managed to get a foothold in a low level account finds a way to bump themselves up to a much higher level of access, like DMT Reviewer or System Administrator. From there they suddenly has access to all sorts of sensitive parts of the system that they should never have been anywhere near.

30. Lateral Movement Once the attacker is in one small corner of the system they do not just stay there. They start quietly moving sideways, getting into other accounts, other components, other databases, slowly working their way towards the really high value targets like model configuration or alert approval. An initial small breach can eventually turn into something much more serious.

31. Insider Threat → Malicious Credential Misuse This is honestly one of the scariest ones on the list because it is someone who already has full legitimate access doing the damage from inside. They might start suppressing real alerts, waving through fake ones, or quietly passing sensitive data to someone on the outside. Could be for money, could be a personal grudge, could be because someone out there is threatening or paying them.

32. Insider Threat → Negligent Misconfiguration This one is not about bad intentions at all, it is just about someone making a genuine mistake. A staff member with admin access accidentally sets something up wrong, maybe disables a validation rule without realising it or opens up a network port that should have stayed shut. The damage was not intentional but the gap it creates is very real and could easily be exploited by someone else down the line.

33. Insider Threat → Data Exfiltration A malicious insider with database access decides to quietly copy out sensitive records or model training data and send it to someone on the outside. That information could then be used to work out how Phoenix operates and figure out the best ways to get around its detection capabilities.

34. Insider Threat → Alert Suppression A DMT Reviewer who has been turned or who has their own agenda starts deliberately marking real threats as false positives so that genuine alerts never makes it out to the public during an active disaster. Because it all looks like completely normal reviewing behaviour on the surface, it is really difficult to catch without solid audit logging and anomaly detection backing things up.

CATEGORY 3 → DATABASE AND STORAGE ATTACKS (TRUST BOUNDARY 2)

35. SQL Injection This is where an attacker sneaks malicious SQL code into an input field or an API request that connects through to the Scam DB or Cyber Threat DB. If it works they can basically do whatever they want in there, read records they should not be seeing, change things around, delete stuff, or in some cases even run commands directly on the underlying database server.

36. NoSQL Injection Same general idea as SQL injection but aimed at NoSQL databases this time. By messing around with the query structure in the right way, an attacker can sneak past the authentication, pull out data they have no business seeing, or corrupt records sitting inside the Scam DB or Cyber Threat DB.

37. Scam DB Data Poisoning This is where false or manipulated records get deliberately slipped into the Scam DB, either through a compromised part of the pipeline or by someone on the inside with access. Because the AI model keeps going back to this database to look at historical scam records when it is trying to classify things, bad data in here directly drags down the whole detection accuracy of the system.

38. Cyber Threat DB Data Poisoning Same concept but this time the target is the structured threat intelligence records, things like known attack patterns, indicators of compromise, and adversary tactics. Corrupting this data does not just mess up the AI model, it also throws off the way the Correlation Engine is reading and assessing risk across the board.

39. Unauthorised Direct Write Access This is where an attacker finds a way to completely bypass the validated pipeline and just writes data directly into the Scam DB or Cyber Threat DB without going through any of the proper checks. Maybe there is a misconfigured network rule they can exploit or a vulnerability in the database itself. Either way every single validation control Phoenix has in place gets completely skipped over.

40. Database Enumeration Before doing anything too dramatic, the attacker spends time just quietly poking around and mapping out the database structure, figuring out what tables are there, what records exist, how everything is organised. They are not necessarily stealing anything yet, they are just building up a detailed picture of the landscape so they know exactly where to strike when they are ready.

41. Ransomware Encryption of Databases The attacker drops ransomware into the system that just locks down the entire Scam DB and Cyber Threat DB by encrypting all of it. The AI model stops working, the Correlation Engine goes with it, and the whole system essentially becomes useless. During an active disaster when every minute matters, the pressure to pay up and get back online fast can be absolutely enormous.

42. Backup Corruption This one is particularly nasty because the attacker quietly corrupts the backups first before they then go after the main system with ransomware or a deletion attack. So when the operators try to restore things they discover the backups are already broken and they have no clean copy to fall back on without either paying the ransom or starting the whole rebuild from scratch.

43. Log Tampering After doing something malicious in the database the attacker goes back in and cleans up all the logs so there is absolutely no trace left of what happened. Without those logs it becomes incredibly hard for anyone trying to investigate to work out what was done, when exactly it happened, or which records were affected.

44. Targeted Record Deletion Rather than making a big noisy mess with ransomware, the attacker just quietly deletes specific scam or threat records from the database. This slowly chips away at the AI model's training data and detection accuracy over time without setting off any major alarms, which makes it a really difficult attack to even notice until the damage is already well and truly done.

CATEGORY 4 → AI MODEL ATTACKS (TRUST BOUNDARY 3)

45. Adversarial Input Attack This is where an attacker sits down and carefully crafts inputs, like a scam message or a social media post, that is specifically designed to trick Phoenix's AI model into thinking malicious content is completely harmless. They do not even need direct access to the model to figure this out, they can just keep testing different things and watching what gets flagged and what does not until they works out what slips through.

46. Model Evasion This is basically the same idea but as an ongoing thing rather than a one off attempt. The attacker keeps tweaking and adjusting their content to make sure it always stays just below the detection threshold, constantly adapting as the model evolves. Its like a never ending game of cat and mouse where the attacker is always trying to be one step ahead.

47. Model Inversion Attack The attacker keeps sending carefully chosen inputs to the AI model and pays close attention to what comes back each time. By analysing all of those responses over time they can gradually piece together information about what the model was trained on and what patterns it has learned to look for. They can then use that knowledge to design content that specifically avoids those patterns.

48. Membership Inference Attack This attack is about trying to figure out whether a specific piece of data was actually used to train the model. The attacker looks at how confident the model is when it encounters a particular record and uses that to work out whether it was part of the training set. For Phoenix this could end up exposing sensitive information about real scam reports that went into training the system.

49. Data Poisoning via Adversarial Feedback The attacker starts feeding in misleading feedback through the Community Feedback module, flipping things around by saying real threats are false alarms and false alarms are real threats. If this keeps going for long enough and enough of it makes it into the retraining pipeline, the model gradually starts drifting in a direction that works in the attacker's favour.

50. Label Flipping Attack This is a really damaging form of data poisoning where the attacker flips the labels on training examples so the model ends up learning completely the wrong things. Known scam content gets labelled as safe, safe content gets labelled as a threat. The effects of this can spread across huge chunks of the model's behaviour and can be really difficult to undo once it has taken hold.

51. Confidence Score Manipulation The attacker crafts inputs that tricks the model not just into misclassifying something, but into being extremely confident about that wrong classification. That is the really dangerous part because when the model is very confident about something the Correlation Engine is far less likely to send it back for a second look.

52. Gradient-Based Adversarial Example Generation This uses some pretty advanced maths that exploits how neural networks work under the hood to create inputs that looks almost identical to legitimate content but causes the model to get it completely wrong. You need some knowledge of

the model's architecture to do this properly but it can be roughly achieved even without having full direct access to it.

53. Transfer Attack Using a Surrogate Model The attacker builds their own separate AI model that works similarly to Phoenix and uses that to develop and test adversarial content. They then check whether the same content also fools the real Phoenix system. This means they can develop effective attacks without ever needing to directly touch or access Phoenix itself.

54. Urgency Detection Bypass Phoenix is trained to pick up on urgent language like "Act now" or "Do not delay". So the attacker just rewrites those kinds of phrases into something that sounds a bit different but carries exactly the same meaning, like "Your immediate attention is required". The reader still feels the same sense of urgency but Phoenix does not flag it because the specific patterns it was trained on are not there anymore.

55. Scam Detection Evasion Through Paraphrasing The attacker takes scam templates that the model already knows how to recognise and just keeps rewriting them in different ways. The underlying intent of the scam stays exactly the same but the wording and structure keeps changing just enough that the model keeps failing to recognise it as something it has already seen.

56. Black-Box Model Probing This is basically reconnaissance work. The attacker sends loads and loads of different inputs through Phoenix and carefully notes down what gets flagged and what does not. Over time this builds up a pretty clear picture of where the model's detection boundaries sit, which can then be used to craft content that falls just on the safe side of those boundaries.

CATEGORY 5 → STREAM PROCESSING AND PIPELINE ATTACKS (KAFKA / FIREBASE)

57. Kafka Topic Poisoning If an attacker manages to get into the Kafka broker, maybe through a service account that has been compromised or a network that has not been properly locked down, they can start injecting fake messages directly into the topics that Phoenix reads from. The really concerning thing about this is that by the time this data is in the stream, the Data Validation step has already run, so the bad data just flows through unchecked.

58. Kafka Consumer Group Hijacking The attacker registers their own fake consumer into the same consumer group as one of Phoenix's legitimate components. After that some of the messages that was supposed to go to Phoenix starts going to the attacker instead. They can quietly read all that data, or they can just let it disappear which creates gaps and holes in Phoenix's processing that nobody immediately notices.

59. Kafka Denial-of-Service The attacker just drowns Kafka in messages until the broker runs out of capacity and legitimate processing grinds to a stop. During a disaster when the system is already dealing with heavier traffic than normal, this kind of attack can quite easily be the thing that pushes everything completely over the edge.

60. Firebase Unauthorised Access Firebase is only going to be as secure as however its security rules have been set up, and if those rules have not been configured properly an attacker can get in and start reading or writing to the real time database components that Phoenix uses for community facing features. This kind of misconfiguration is actually pretty common and can expose feedback data or allow someone to slip false data quietly into the pipeline.

61. Firebase Data Injection If the Firebase security rules are too permissive, an attacker can just write their own data directly into Firebase without going through any of the proper validation steps.

This sneaks false records into the community feedback or alert delivery parts of the system without any of Phoenix's normal checks ever getting a chance to catch it.

62. Message Broker Authentication Bypass If there is a flaw in the way Kafka or Firebase handles authentication, an attacker might be able to get into the message broker without needing any valid credentials at all. Once they are in they can basically do whatever they want with the messages that are flowing through the entire stream processing layer.

63. Pipeline Race Condition Exploitation This is a subtle one that exploits the timing between different steps in the pipeline. If an attacker can slip data in at exactly the right moment, after the validation has already run but before it reaches the AI model, they can get unvalidated content all the way into the system without any of the security controls ever having a chance to pick it up.

CATEGORY 6 → ALERT SYSTEM ATTACKS (ENTRY POINT 6 & TRUST BOUNDARY 5)

64. Alert API Interception The attacker intercepts the API calls that Phoenix sends out when it is trying to push alerts through to channels like SMS gateways or VicEmergency. Once they have grabbed those calls they can read what the alerts say, change the content before it gets delivered, or just drop them entirely so nobody ever receives anything.

65. Alert Content Tampering This is where the attacker positions themselves in the middle of the alert delivery process and starts altering what the alerts actually say. Evacuation routes, threat descriptions, safety instructions, all of it could be replaced with completely wrong or misleading information before it reaches the communities and emergency services that depend on it.

66. Alert Suppression Attack The attacker quietly intercepts and drops alert commands before they ever make it to the delivery channels, so communities just never receive the warnings at all. What makes this one particularly dangerous is that Phoenix has no idea anything has gone wrong. It thinks the alerts were sent out successfully while people on the ground are receiving nothing.

67. Replay Attack on Alert API The attacker captures a real alert delivery command from some earlier point and then replays it again later in a different context. This could end up causing Phoenix to send out the exact same emergency alert over and over again which very quickly starts eroding public trust and makes people start dismissing alerts as system errors.

68. Alert Channel Spoofing The attacker does not even need to get anywhere near Phoenix to pull this off. They just impersonate the official Phoenix alert channel and start pushing out fake emergency alerts that look exactly like they came from the real system. People trust the channel so they take the alerts seriously, and that trust is exactly what the attacker is exploiting here.

69. SMS Gateway Compromise The attacker gets unauthorised access to the SMS gateway that Phoenix uses to send out text alerts. With that access they can read messages, change them, block them, send them somewhere else entirely, or even push out completely fake alerts that appear to be coming from the official Phoenix number.

70. Push Notification Hijacking via Firebase By finding and exploiting misconfigurations or vulnerabilities in the way Phoenix uses Firebase for push notifications, an attacker can intercept or alter push alerts before they reach people's phones, or just stop them from ever being delivered at all during a disaster situation.

71. Rate Limiting Abuse on Alert Delivery The attacker floods the alert API with so many requests that it hits the rate limit and starts blocking or slowing down the real legitimate alerts. In the first critical minutes of a disaster when those warnings matters the most, even a small delay can have genuinely serious consequences for people in the affected areas.

CATEGORY 7 → COMMUNITY FEEDBACK AND RETRAINING ATTACKS (ENTRY POINTS 4 & 5)

72. Spam Flooding of Feedback Module The attacker just starts submitting huge volumes of useless or deliberately misleading reports through the Community Feedback module. The whole point is to clog up the feedback pipeline so badly that the retraining signal becomes so noisy and unreliable that the model stops learning anything genuinely useful from it.

73. Adversarial Feedback Submission This is where an attacker submits feedback that is intentionally backwards, labelling real threats as false alarms and false alarms as real threats. If enough of this bad feedback keeps making it into the retraining pipeline over time, the model gradually starts shifting its classifications in a direction that suits the attacker perfectly.

74. Coordinated Disinformation Feedback Campaign This is the same idea as adversarial feedback but done at a much bigger scale with multiple people all pushing the same kind of false feedback at once. A coordinated effort like this can cause really significant damage to the model's accuracy much faster than any single person working alone ever could.

75. Official Agency Impersonation The attacker submits completely false threat reports while pretending to be Victoria Police or the Country Fire Authority. Because Phoenix gives the highest confidence weighting to reports that appears to come from official agencies, even just one successfully faked official submission can cause a disproportionately large amount of damage to what the model ends up learning.

76. Third-Party Report Interception and Alteration The attacker intercepts real threat reports that is on their way from Police, Fire, Rescue or Government agencies and changes the content before it gets to Phoenix. This is especially damaging because these reports is the ones Phoenix trusts most, and now that trust is effectively being weaponised against it.

77. Feedback Timing Attack The attacker waits until just before a scheduled retraining run is about to kick off and then dumps a massive volume of adversarial feedback into the system right at that moment. The whole idea is to maximise how much damage gets baked into the newly retrained model before anyone has a chance to spot the corrupted feedback and pull it out.

78. Ground Truth Manipulation This involves going after the external sources that Phoenix uses to verify whether a detected threat is actually genuine. If those confirmation systems gets compromised, the ground truth signals that the model depends on for its supervised retraining becomes completely untrustworthy, and the model starts learning from corrupted information without anyone even realising it is happening.

CATEGORY 8 → PHYSICAL AND INFRASTRUCTURE ATTACKS

79. Physical Access to Server Infrastructure This one is old school but still very much a real threat. If an attacker physically gets into the facility where Phoenix's servers is housed, they can mess with the hardware directly, plug in devices to capture data, or just physically wreck the infrastructure. During

a disaster when security staff might be stretched thin or pulled away to other priorities, this kind of risk becomes even more of a concern.

80. Power Infrastructure Attack If the attacker can cut the power to wherever Phoenix is hosted during an active disaster, the whole system just goes dark at the absolute worst possible moment. Cloud infrastructure usually has some level of redundancy built in but on premises equipment and local networking gear can still be caught out badly by this kind of attack.

81. Network Infrastructure Attack This involves going after the actual physical network that Phoenix depends on to function, things like routers, switches and fibre connections. If those gets taken out, Phoenix cannot communicate between its own components anymore and it cannot get alerts out to the people who desperately needs them.

82. Hardware Supply-Chain Attack This is probably one of the hardest attacks to detect because it happens long before Phoenix even gets set up and running. The attacker compromises hardware like servers or network equipment during the manufacturing or delivery process so that backdoors or vulnerabilities is already quietly baked in by the time the equipment gets deployed. Nobody knows they is there and nobody thinks to look.

Summary Table

#	Attack Name	Category	Severity
1	API Key Compromise	External Data Feed	High
2	Man-in-the-Middle Attack	External Data Feed	High
3	DNS Spoofing	External Data Feed	High
4	DoS / DDoS Attack	External Data Feed	High
5	Feed Replay Attack	External Data Feed	Medium
6	SSL/TLS Certificate Spoofing	External Data Feed	High
7	Supply-Chain Attack on Data Provider	External Data Feed	Critical
8	Data Poisoning via False Scam Submissions	External Data Feed	High
9	API Rate-Limiting Attack	External Data Feed	Medium
10	Deliberate Threat Indicator Flooding	External Data Feed	Medium
11	Schema Manipulation Attack	External Data Feed	Medium
12	Timestamp Manipulation	External Data Feed	Medium
13	Geolocation Spoofing	External Data Feed	Medium
14	Coordinated Bot Campaign	External Data Feed	High

#	Attack Name	Category	Severity
15	Brute Force Attack	Authentication	High
16	Credential Stuffing	Authentication	High
17	Spear-Phishing Against DMT Staff	Authentication	Critical
18	General Phishing Campaign	Authentication	High
19	Session Hijacking	Authentication	High
20	Session Fixation	Authentication	Medium
21	Cross-Site Request Forgery (CSRF)	Authentication	Medium
22	Cross-Site Scripting (XSS)	Authentication	High
23	MFA Bypass via SIM Swapping	Authentication	High
24	OAuth Token Theft	Authentication	High
25	Password Reset Abuse	Authentication	Medium
26	Account Takeover via Personal Email	Authentication	High
27	Privilege Escalation	Authentication	Critical
28	Lateral Movement	Authentication	Critical
29	Insider — Malicious Credential Misuse	Insider Threat	Critical
30	Insider — Negligent Misconfiguration	Insider Threat	High
31	Insider — Data Exfiltration	Insider Threat	Critical
32	Insider — Alert Suppression	Insider Threat	Critical
33	SQL Injection	Database	Critical
34	NoSQL Injection	Database	Critical
35	Database Data Poisoning	Database	High
36	Unauthorised Direct Write Access	Database	Critical
37	Database Enumeration	Database	Medium
38	Ransomware Encryption of Databases	Database	Critical
39	Backup Corruption	Database	Critical

#	Attack Name	Category	Severity
40	Log Tampering	Database	High
41	Targeted Record Deletion	Database	High
42	Adversarial Input Attack	AI Model	High
43	Model Evasion	AI Model	High
44	Model Inversion Attack	AI Model	Medium
45	Membership Inference Attack	AI Model	Medium
46	Data Poisoning via Adversarial Feedback	AI Model	High
47	Label Flipping Attack	AI Model	High
48	Confidence Score Manipulation	AI Model	High
49	Gradient-Based Adversarial Example	AI Model	High
50	Transfer Attack via Surrogate Model	AI Model	High
51	Urgency Detection Bypass	AI Model	Medium
52	Scam Detection Evasion via Paraphrasing	AI Model	High
53	Black-Box Model Probing	AI Model	Medium
54	Kafka Topic Poisoning	Stream Processing	High
55	Kafka Consumer Group Hijacking	Stream Processing	High
56	Kafka Denial-of-Service	Stream Processing	High
57	Firebase Unauthorised Access and Data Injection	Stream Processing	High
58	Message Broker Authentication Bypass	Stream Processing	Critical
59	Pipeline Race Condition Exploitation	Stream Processing	Medium
60	Alert API Interception	Alert System	Critical
61	Alert Content Tampering	Alert System	Critical
62	Alert Suppression Attack	Alert System	Critical
63	Replay Attack on Alert API	Alert System	High
64	Alert Channel Spoofing	Alert System	Critical

#	Attack Name	Category	Severity
65	SMS Gateway Compromise	Alert System	Critical
66	Push Notification Hijacking	Alert System	High
67	Rate Limiting Abuse on Alert Delivery	Alert System	Medium
68	Spam Flooding of Feedback Module	Feedback & Retraining	Medium
69	Adversarial Feedback Submission	Feedback & Retraining	High
70	Coordinated Disinformation Feedback Campaign	Feedback & Retraining	High
71	Official Agency Impersonation	Feedback & Retraining	Critical
72	Third-Party Report Interception and Alteration	Feedback & Retraining	Critical
73	Feedback Timing Attack	Feedback & Retraining	Medium
74	Ground Truth Manipulation	Feedback & Retraining	High
75	Physical Server Access	Physical Infrastructure	Critical
76	Power Infrastructure Attack	Physical Infrastructure	High
77	Network Infrastructure Attack	Physical Infrastructure	High
78	Hardware Supply-Chain Attack	Physical Infrastructure	Critical

Identify Vulnerabilities

Before jumping into the vulnerabilities it is important to understand what a vulnerability actually is because it is easy to confuse it with an attack. A vulnerability is the weakness in the system, an attack is when someone actually exploits that weakness. Think of it like an unlocked window in your house the unlocked window is the vulnerability and someone climbing through it is the attack. What we are doing here is finding all the unlocked windows in Phoenix before anyone tries to climb through them. For Phoenix this matters more than it would for a normal system because it operates during natural disasters, exactly when attackers are most active and the consequences of a security failure are most serious. The vulnerabilities below have been identified by going through every part of the Phoenix architecture and asking one simple question at each step what weakness here could an attacker exploit?

Vulnerability Category 1 — External Data Feed Vulnerabilities

These vulnerabilities are about the data coming into Phoenix from outside sources like BoM, Scamwatch and social media. This is the first place Phoenix connects to the outside world so any

weakness here affects everything that comes after it.

V1 — No Continuous Check on Feed Content After Authentication

Phoenix checks that incoming feeds are coming from the right source using API keys and certificates but once that initial check passes it does not keep verifying whether the actual content has been tampered with. If an attacker managed to get inside a trusted data source and started changing the data being sent Phoenix would have no way of knowing because it already decided to trust that source. It is like checking someone's ID at the door and then never watching them again even if they start doing something suspicious.

V2 — No Detection of Unusual Patterns in Incoming Data

The validation component checks that incoming data looks right in terms of format and structure but it does not check whether the content actually makes sense compared to what has come before. If someone suddenly flooded the system with thousands of fake scam reports all at once the system would process them without raising any alarm. It is like a security guard who checks that your badge looks right but never notices that you are carrying something you should not be.

V3 — If One Data Source Goes Down There Is No Backup

If a primary external feed like BoM or Scamwatch goes offline during a disaster whether because of a technical failure or a deliberate attack — Phoenix has a retry mechanism but no automatic backup source to switch to. A sustained attack against one of these providers could leave Phoenix completely blind during exactly the period when it needs that information most.

V4 — Social Media APIs Can Be Forced to Cut Phoenix Off

Social media platforms like Twitter/X and Facebook limit how many requests any system can make within a certain time window. If an attacker deliberately floods these APIs with requests they can trick the platform into temporarily cutting off Phoenix's access creating a gap in monitoring for scams and misinformation right when social media activity is at its highest during a disaster.

Vulnerability Category 2 — Authentication and Access Vulnerabilities

These vulnerabilities are about who can get into Phoenix and what they can do once they are inside. This is one of the most critical areas because Phoenix's most powerful functions approving public alerts and configuring AI models are controlled by human operators whose accounts could be compromised.

V5 — DMT Staff Are More Vulnerable to Social Engineering During Disasters

Multi-factor authentication protects the login portal technically but it cannot protect the humans behind it from being tricked. When DMT staff are already under enormous pressure during a live disaster they are much more likely to fall for a convincing phishing email or respond to a fake urgent request than they would be on a normal day. Attackers know this and deliberately time their social engineering campaigns to coincide with disaster events. No technical fix fully solves this it requires ongoing training and clear communication protocols for high-pressure situations.

V6 — Wrong Permission Settings Could Give Someone Too Much Access

So RBAC is basically the system that decides who can do what inside Phoenix. the idea is that a Read-Only Analyst should only be able to view things, a DMT Reviewer can action things and an Administrator can change system settings. but if someone sets up those permissions incorrectly even just by accident during a routine update a lower level user could suddenly find themselves able to do things they were never supposed to do like approving public alerts or changing how the AI model works. in a system like Phoenix where those kinds of actions have real consequences for real people during a disaster that is not a small problem at all.

V7 — Session Tokens Can Be Stolen and Reused

so basically when someone logs into Phoenix successfully the system gives them a session token which is kind of like a digital pass that proves they are who they say they are. the problem is if that

token gets stolen somewhere along the way an attacker can just use it to get straight into the system without needing the person's password or even going through MFA. It's honestly like someone stealing your work ID card and just walking into the building with it like nothing happened.

V8 — Legitimate Users Can Cause Harm Without Triggering Any Alert

Role-Based Access Control governs what authenticated users are allowed to access but it does not monitor what they actually do within those permissions. A malicious insider who uses their own legitimate credentials to suppress genuine alerts, corrupt training data, or exfiltrate threat intelligence would not trigger any access control alarm because from the system's perspective they are doing exactly what they are permitted to do. Without behavioural monitoring on top of access control this vulnerability stays wide open.

Vulnerability Category 3 — Database and Storage Vulnerabilities

These vulnerabilities are about the Scam DB and Cyber Threat DB the two databases that store Phoenix's accumulated threat intelligence and feed the AI model. Because everything the AI model does depends on these databases any weakness here affects the entire system downstream.

V9 — Malicious Code Could Reach the Database Layer

Even though data passes through validation and preprocessing before being written to the databases if the sanitisation at the database write boundary is not thorough enough malicious content like SQL or NoSQL injection payloads could slip through and execute unintended commands in the database. Because both databases feed directly into the AI model's classifications and the Correlation Engine's risk scoring a successful injection attack here would corrupt the intelligence driving every decision Phoenix makes.

V10 — No Permanent Record of What Happened to the Data

If database operations reads, writes and deletes are not logged to an immutable audit trail then anyone who modifies or deletes records could do so without leaving any traceable evidence. This makes it almost impossible to detect slow quiet attacks like targeted record deletion or gradual data poisoning and makes recovery from any data integrity incident extremely difficult because you cannot establish what was changed and when.

V11 — Backups Could Be Wiped Out Along With the Primary Data

Phoenix's databases build up years worth of valuable threat intelligence over time. If the backup copies are stored in the same environment as the primary databases or protected by weaker access controls a ransomware attack could wipe out both the primary data and the backups simultaneously leaving no path to recovery without rebuilding everything from scratch which during an active disaster response would be catastrophic.

V12 — Fake Records Added Slowly Could Corrupt the AI Model

The AI model learns from the historical records stored in the Scam DB so if those records are not accurate the model is not going to be accurate either. The scary thing about this vulnerability is that it does not need to happen overnight. Someone could just keep quietly adding fake but believable records over weeks or months and the model would slowly start learning the wrong things without anyone noticing until the detection accuracy has already dropped significantly and by that point fixing it is not easy.

Vulnerability Category 4 — AI Model Vulnerabilities

These vulnerabilities are specifically about the AI models that power Phoenix's threat detection. AI systems are powerful but they have known weaknesses that adversaries can deliberately exploit if they understand how the models work.

V13 — AI Models Can Be Fooled by Carefully Crafted Content

Phoenix's AI models are trained to classify content that resembles what they have seen before. But

content that has been deliberately designed to sit just outside the model's decision boundaries called adversarial inputs can cause the model to produce confidently wrong classifications without any indication that something is wrong. This is a known limitation of all machine learning systems and cannot be completely eliminated. It can only be managed through continuous retraining, confidence threshold checks and human review of high-risk decisions.

V14 — Corrupted Feedback Could Make the AI Model Worse Over Time

The model retraining pipeline is designed to make Phoenix smarter after every disaster event. But if the feedback feeding into that pipeline is deliberately corrupted through fake community submissions, impersonation of official agencies or insider manipulation of review decisions the retraining process will actually make the model worse rather than better. This is one of the most dangerous vulnerabilities in Phoenix because it turns the improvement mechanism against itself and the degradation happens gradually enough to go unnoticed for a long time.

V15 — The AI Model Cannot Explain Its Own Decisions

Phoenix's deep learning models produce classifications without providing a human-readable explanation of how they reached that conclusion. This means DMT reviewers cannot easily tell why the model flagged a particular piece of content, cannot identify when the model is behaving unexpectedly and cannot explain decisions to external stakeholders who need to trust the system. In a high-stakes emergency context where accountability and public trust are critical the inability to explain AI decisions is a meaningful weakness.

Vulnerability Category 5 — Stream Processing Vulnerabilities

These vulnerabilities are about Apache Kafka and Firebase - the components responsible for routing data through the Phoenix pipeline in real time.

V16 — Kafka Broker Could Be Accessed by Unauthorised Users

Kafka is the backbone of Phoenix's data pipeline. If the Kafka broker is not properly secured for example if default credentials have not been changed, topic-level access controls are missing or the broker is reachable from outside the intended network an attacker who gets access can read, modify or inject messages across the entire pipeline simultaneously. Because every downstream component reads from Kafka a compromised broker is one of the most damaging vulnerabilities in the entire architecture.

V17 — Data Could Be Tampered With Between Pipeline Stages

Phoenix processes data step by step validation first then stream processing then preprocessing then the AI model. between each of those steps there is a tiny window where the data has already passed one check but has not reached the next one yet. in theory if someone had access to the pipeline at exactly the right moment they could change the data during that gap. it is not the easiest thing to pull off but the gap is real and worth being aware of.

Vulnerability Category 6 — Alert System Vulnerabilities

These vulnerabilities are about the final stage of Phoenix actually getting alerts out to communities, emergency services and government authorities.

V18 — Phoenix Cannot Control What Happens to Alerts After They Leave

Once an alert leaves Phoenix and enters an external delivery channel an SMS gateway, email server or VicEmergency Phoenix has no visibility over what happens to it. If any of those external channels is independently compromised the alert could be intercepted, modified or suppressed without Phoenix ever knowing. The system logs that it sent the alert but cannot verify that it arrived unchanged at the other end.

V19 — No Way to Confirm That Alerts Were Actually Received

Phoenix can confirm when it successfully sends an alert but it has no mechanism to verify in real

time that the alert was actually received and read by the people it was intended for. During a disaster when communications infrastructure is already degraded an alert that appears successfully delivered on Phoenix's end might never have reached the community members who needed it most.

Vulnerability Category 7 — Community Feedback Vulnerabilities

These vulnerabilities are about the Community Feedback module the open channel through which community members and third-party responders can submit reports and provide feedback on alerts.

V20 — Anyone Can Submit Feedback and the Content Is Not Deeply Validated

The Community Feedback module is deliberately open to a wide range of users including the general public. While official agency submissions are weighted more heavily general community submissions are authenticated but not deeply validated for content accuracy. A determined adversary who submits plausible-looking but false feedback consistently over time could gradually influence the model retraining pipeline without any single submission being obviously suspicious enough to be filtered out.

V21 — The Quality Filter on Feedback Is Not Foolproof

The Discard if Irrelevant filter is designed to catch low-quality or adversarially crafted feedback before it enters the training pipeline. But the effectiveness of this filter depends on its own training data which means if the filter itself has been exposed to poisoned examples it may not catch adversarial submissions reliably. This creates a circular dependency that is difficult to fully resolve and leaves a residual vulnerability in the feedback and retraining pipeline.

Summary of Vulnerabilities

#	Vulnerability	Category	Severity
V1	No continuous check on feed content after authentication	External Data Feed	High
V2	No detection of unusual patterns in incoming data	External Data Feed	High
V3	Single point of failure on external API connections	External Data Feed	High
V4	Social media APIs can be forced to cut Phoenix off	External Data Feed	Medium
V5	DMT staff more vulnerable during disasters	Authentication	Critical
V6	Wrong permission settings could give too much access	Authentication	Critical
V7	Session tokens can be stolen and reused	Authentication	High
V8	Legitimate users can cause harm without triggering alerts	Authentication	Critical
V9	Malicious code could reach the database layer	Database	Critical
V10	No permanent record of what happened to the data	Database	High
V11	Backups could be wiped out along with primary data	Database	Critical
V12	Fake records added slowly could corrupt the AI model	Database	High

#	Vulnerability	Category	Severity
V13	AI models can be fooled by carefully crafted content	AI Model	High
V14	Corrupted feedback could make AI model worse over time	AI Model	Critical
V15	AI model cannot explain its own decisions	AI Model	High
V16	Kafka broker could be accessed by unauthorised users	Stream Processing	Critical
V17	Data could be tampered with between pipeline stages	Stream Processing	Medium
V18	Phoenix cannot control alerts after they leave	Alert System	Critical
V19	No way to confirm alerts were actually received	Alert System	Medium
V20	Anyone can submit feedback with no deep content check	Community Feedback	High
V21	Quality filter on feedback is not foolproof	Community Feedback	High

Why Identifying Vulnerabilities Matters for Phoenix

The reason we identify vulnerabilities separately from attacks is because one vulnerability can be the root cause of many different attacks at once. Fixing V14 for example the corrupted feedback vulnerability would protect Phoenix against adversarial feedback submissions, label flipping attacks, coordinated disinformation campaigns and agency impersonation all in one go. So instead of trying to defend against 78 individual attacks one by one the team can focus on fixing the 21 underlying vulnerabilities that make those attacks possible in the first place. That is a much smarter and more efficient way to build a genuinely secure system.

Map Threats

Ok so this is basically the part where everything we have done so far finally comes together. we have already figured out who the attackers are, what attacks they could launch and what vulnerabilities make those attacks possible. now we are connecting all of that into one clear picture so instead of having three separate lists that dont talk to each other we have one joined up view that shows exactly what is going on.

think of it like this if the attacker is the person trying to break in, the vulnerability is the unlocked window and the attack is them climbing through it, then the threat map is basically a diagram that shows which person is going for which window in which part of the building. once you can see that you know exactly where to focus your defences.

each row in the threat map connects four things, who the attacker is, what they actually do, which vulnerability they are exploiting and which part of Phoenix gets hit.

Threat Map → Opportunistic Cybercriminals

these are the attackers who are basically just trying to make quick money by taking advantage of scared people during disasters. they are not the most sophisticated but they are the most common.

Attacker	What They Do	Vulnerability They Exploit	Part of Phoenix They Target
Opportunistic Cybercriminals	Flood the system with fake scam reports to confuse the AI	V2 → System does not check if content makes sense	External Cyber Threat and Scam Feeds
Opportunistic Cybercriminals	Use bots to flood social media with false disaster content	V2 → System does not check if content makes sense	External Cyber Threat and Scam Feeds
Opportunistic Cybercriminals	Force social media APIs to cut Phoenix off	V4 → Social media APIs can be forced to block Phoenix	Stream Processing
Opportunistic Cybercriminals	Spam the community feedback module with false reports	V20 → Anyone can submit feedback with no deep check	Community Feedback Module
Opportunistic Cybercriminals	Submit fake feedback to corrupt how the AI learns	V21 → Quality filter on feedback is not foolproof	Model Retraining Pipeline

Threat Map → State-Sponsored APT Actors

these are the most dangerous attackers. they are well funded, very patient and they plan everything carefully before striking. they usually go after the most sensitive parts of the system.

Attacker	What They Do	Vulnerability They Exploit	Part of Phoenix They Target
State-Sponsored APT	Send targeted phishing emails to DMT staff to steal credentials	V5 → DMT staff are more vulnerable during disasters	DMT User Login Portal
State-Sponsored APT	Compromise a trusted data provider at the source	V1 → No continuous check on feed content after login	External Disaster Data APIs
State-Sponsored APT	Redirect API calls to a fake server using DNS spoofing	V1 → No continuous check on feed content after login	External Disaster Data APIs
State-Sponsored APT	Move through the system quietly after getting initial access	V8 → Legitimate users can cause harm without triggering alerts	DMT Login and Internal Functions

Attacker	What They Do	Vulnerability They Exploit	Part of Phoenix They Target
State-Sponsored APT	Block emergency alerts from reaching communities	V18 → Phoenix cannot control alerts after they leave	Alert System API Endpoints
State-Sponsored APT	Gain administrator access through privilege escalation	V6 → Wrong permission settings could give too much access	DMT Login and Internal Functions

Threat Map → Hacktivists

these attackers are motivated by politics or ideology rather than money. they want to make a point and they are willing to disrupt the system to do it.

Attacker	What They Do	Vulnerability They Exploit	Part of Phoenix They Target
Hacktivists	Flood disaster data provider with requests until it goes offline	V3 → No backup if one data source goes down	External Disaster Data APIs
Hacktivists	Try thousands of stolen passwords against the DMT login	V5 → DMT staff are more vulnerable during disasters	DMT User Login Portal
Hacktivists	DDoS attack against the alert system to stop alerts going out	V18 → Phoenix cannot control alerts after they leave	Alert System API Endpoints
Hacktivists	Send fake official alerts pretending to be Phoenix	V19 → No way to confirm alerts were actually received	Alert System
Hacktivists	Steal and leak internal DMT review records publicly	V8 → Legitimate users can cause harm without triggering alerts	Databases

Threat Map → Insider Threats

these are people already inside the system — DMT staff, administrators or contractors — who misuse their access either on purpose or by accident. they are scary because they do not need to break through any security controls — they are already past them.

Attacker	What They Do	Vulnerability They Exploit	Part of Phoenix They Target
Insider Threats	Deliberately mark real threats as false alarms to suppress alerts	V8 → Legitimate users can cause harm without triggering alerts	DMT Review Component

Attacker	What They Do	Vulnerability They Exploit	Part of Phoenix They Target
Insider Threats	Add corrupted records directly into the databases	V9 → Malicious code could reach the database layer	Scam DB and Cyber Threat DB
Insider Threats	Quietly delete important threat records from the databases	V10 → No permanent record of what happened to the data	Scam DB and Cyber Threat DB
Insider Threats	Set up permissions incorrectly giving someone too much access	V6 → Wrong permission settings could give too much access	DMT Login and Internal Functions
Insider Threats	Steal sensitive threat intelligence and send it externally	V8 → Legitimate users can cause harm without triggering alerts	Scam DB and Cyber Threat DB
Insider Threats	Feed wrong information into the model retraining pipeline	V14 → Corrupted feedback could make AI model worse over time	Model Retraining Pipeline

Threat Map → Organised Cybercrime Groups

these are professional criminal organisations who treat attacking systems like a business. they plan carefully, use sophisticated tools and go after the highest value targets. the Fire Rescue Victoria ransomware attack is a real example of this exact attacker type hitting an Australian emergency services organisation.

Attacker	What They Do	Vulnerability They Exploit	Part of Phoenix They Target
Organised Cybercrime	Encrypt all database contents with ransomware	V11 → Backups could be wiped out along with primary data	Scam DB and Cyber Threat DB
Organised Cybercrime	Send targeted phishing to DMT staff to get inside the system	V5 → DMT staff are more vulnerable during disasters	DMT User Login Portal
Organised Cybercrime	Break into the Kafka broker to manipulate the data pipeline	V16 → Kafka broker could be accessed by unauthorised users	Stream Processing
Organised Cybercrime	Use SQL injection to corrupt or steal database records	V9 → Malicious code could reach the database layer	Scam DB and Cyber Threat DB
Organised Cybercrime	Destroy database backups before launching main attack	V11 → Backups could be wiped out along with primary data	Scam DB and Cyber Threat DB

Attacker	What They Do	Vulnerability They Exploit	Part of Phoenix They Target
Organised Cybercrime	Steal a session token to get into the system without a password	V7 → Session tokens can be stolen and reused	DMT Login and Internal Functions

Threat Map → Misinformation Actors

These attackers do not go after the system directly, they go after the information environment around it. Their goal is to flood Phoenix with so much false content that the AI model starts making wrong decisions without anyone realising it.

Attacker	What They Do	Vulnerability They Exploit	Part of Phoenix They Target
Misinformation Actors	Coordinate mass false feedback submissions to corrupt AI training	V20 → Anyone can submit feedback with no deep check	Community Feedback Module
Misinformation Actors	Create content specifically designed to fool the AI model	V13 → AI models can be fooled by carefully crafted content	AI Model Processing
Misinformation Actors	Keep rephrasing scam templates so the AI does not recognise them	V13 → AI models can be fooled by carefully crafted content	AI Model Processing
Misinformation Actors	Flip correct labels in training data to teach the AI the wrong things	V14 → Corrupted feedback could make AI model worse over time	Model Retraining Pipeline
Misinformation Actors	Pretend to be an official agency to inject high confidence false data	V20 → Anyone can submit feedback with no deep check	Third-Party DMT Reports
Misinformation Actors	Use AI-generated deepfake content to flood social media feeds	V2 → System does not check if content makes sense	External Cyber Threat and Scam Feeds

Full Threat Map Summary

Attacker	Threat	Vulnerability	Component	Severity
Opportunistic Cybercriminals	Fake scam report flooding	V2	Entry Point 2	High
Opportunistic Cybercriminals	Bot campaign on social media	V2	Entry Point 2	High
Opportunistic Cybercriminals	API rate-limiting attack	V4	Stream Processing	Medium
Opportunistic Cybercriminals	Feedback module spam flooding	V20	Entry Point 4	Medium
Opportunistic Cybercriminals	Adversarial feedback submission	V21	Model Retraining	High
State-Sponsored APT	Spear-phishing DMT staff	V5	Entry Point 3	Critical
State-Sponsored APT	Supply-chain attack on data provider	V1	Entry Point 1	Critical
State-Sponsored APT	DNS spoofing	V1	Entry Point 1	High
State-Sponsored APT	Lateral movement after compromise	V8	Trust Boundary 4	Critical
State-Sponsored APT	Alert suppression	V18	Entry Point 6	Critical
State-Sponsored APT	Privilege escalation	V6	Trust Boundary 4	Critical
Hacktivists	DoS against data provider	V3	Entry Point 1	High
Hacktivists	Credential stuffing DMT login	V5	Entry Point 3	High
Hacktivists	DDoS against alert endpoints	V18	Entry Point 6	High
Hacktivists	Fake official alert spoofing	V19	Trust Boundary 5	Critical
Hacktivists	Data exfiltration and public leak	V8	Trust Boundary 2	High
Insider Threats	Malicious alert suppression	V8	DMT Review	Critical
Insider Threats	Direct database data poisoning	V9	Trust Boundary 2	Critical

Attacker	Threat	Vulnerability	Component	Severity
Insider Threats	Targeted record deletion	V10	Trust Boundary 2	High
Insider Threats	RBAC misconfiguration	V6	Trust Boundary 4	Critical
Insider Threats	Threat intelligence exfiltration	V8	Trust Boundary 2	Critical
Insider Threats	Corrupted retraining feedback	V14	Model Retraining	Critical
Organised Cybercrime	Ransomware on databases	V11	Trust Boundary 2	Critical
Organised Cybercrime	Spear-phishing for initial access	V5	Entry Point 3	Critical
Organised Cybercrime	Kafka broker bypass	V16	Stream Processing	Critical
Organised Cybercrime	SQL injection on Scam DB	V9	Trust Boundary 2	Critical
Organised Cybercrime	Backup corruption	V11	Trust Boundary 2	Critical
Organised Cybercrime	Session hijacking	V7	Trust Boundary 4	High
Misinformation Actors	Coordinated disinformation campaign	V20	Entry Point 4	High
Misinformation Actors	Adversarial content evading AI	V13	Trust Boundary 3	High
Misinformation Actors	Model evasion via paraphrasing	V13	Trust Boundary 3	High
Misinformation Actors	Label flipping attack	V14	Model Retraining	Critical
Misinformation Actors	Agency impersonation	V20	Entry Point 5	Critical
Misinformation Actors	AI-generated deepfake flooding	V2	Entry Point 2	High

Why Threat Mapping Matters for Phoenix

So the whole point of threat mapping is that it turns three separate lists into an actual security strategy. without it you have attackers over here, attacks over there and vulnerabilities somewhere else but no clear picture of how they all connect. with it you can see straight away that Trust Boundary 2, the databases is the most heavily targeted part of the entire system, that V5 and V8 are the vulnerabilities being exploited the most and that Insider Threats and Organised Cybercrime Groups are responsible for the highest concentration of Critical severity threats. knowing all of that means the team can focus their energy on fixing the right things in the right places before the system goes live which is exactly what threat modelling is supposed to help you do.

REFERENCES

- Australian Taxation Office. (2020). *SMS scam targeting natural disaster victims promises 8% bonus on tax returns*. <https://www.ato.gov.au/media-centre/sms-scam-targeting-natural-disaster-victims-promises-8-percent-bonus-on-taxreturns>
- Azambuja, A. J. G., Plesker, C., Schützer, K., Anderl, R., Schleich, B., & Almeida, V. R. (2023). Artificial intelligence-based cyber security in the context of Industry 4.0 — A survey. *Electronics*, 12(8). <https://doi.org/10.3390/electronics12081920>
- Chakraborty, S., Mombeshora, E. M., Clark, K. P., & Mbavarira, T. S. (2024). Understanding of cyber-attack vulnerabilities during natural disasters and discussing a cyber-attack resiliency framework. In *SoutheastCon 2024*. <https://doi.org/10.1109/SoutheastCon52093.2024.10500233>
- Chirgwin, R. (2023). *Fire Rescue Victoria still hampered by December 2022 cyber attack*. iTnews. <https://www.itnews.com.au/news/fire-rescue-victoria-still-hampered-by-december2022-cyber-attack-597024>
- Elsworthy, E. (2022). *Concerning spike in scams targeting flood ravaged communities, ACCC says*. SmartCompany. <https://www.smartcompany.com.au/finance/concerning-spike-floodscams-accc/>
- Ghazi, Y., Anwar, Z., Mumtaz, R., Saleem, S., & Tahir, A. (2018). A supervised machine learning based approach for automatically extracting high-level threat intelligence from unstructured sources. In *2018 International Conference on Frontiers of Information Technology (FIT)*. <https://doi.org/10.1109/FIT.2018.00030>
- Huang, L., & Xiao, X. (2024). CTIKG: LLM-powered knowledge graph construction from cyber threat intelligence. *COLM 2024*.
- Hunt, K., Agarwal, P., & Zhuang, J. (2022). Monitoring misinformation on Twitter during crisis events: A machine learning approach. *Risk Analysis*, 42(8), 1728–1748. <https://doi.org/10.1111/risa.13634>
- Husari, G., Al-Shaer, E., Ahmed, M., Chu, B., & Niu, X. (2017). TTPDrill: Automatic and accurate extraction of threat actions from unstructured text of CTI sources. In *Proceedings of the 33rd Annual Computer Security Applications Conference (ACSAC '17)*. Association for Computing Machinery. <https://doi.org/10.1145/3134600.3134646>

Li, Z., Zeng, J., Chen, Y., & Liang, Z. (2022). *AttackKG: Constructing technique knowledge graph from cyber threat intelligence reports*. <https://doi.org/10.48550/arXiv.2111.07093>

Nguyen, K., & Bogle, A. (2020). *The bushfire lies spreading "wildly" on social media*. ABC News. <https://www.abc.net.au/news/2020-01-08/fires-misinformation-being-spread-through-social-media/11846434>

Qian, H., Xia, L., Ge, R., Fan, Y., Wang, Q., & Jing, Z. (2025). From black boxes to glass boxes: Explainable AI for trustworthy deepfake forensics. *Cryptography*, 9(4). <https://doi.org/10.3390/cryptography9040061>

Salley, C. J., Mohammadi, N., & Taylor, J. E. (2023). Safeguarding infrastructure from cyber threats with NLP-based information retrieval. In *2023 Winter Simulation Conference (WSC)*. <https://doi.org/10.1109/WSC60868.2023.10407248>

Scamwatch. (2020). *Bushfires and scams*. Australian Competition and Consumer Commission. <https://www.scamwatch.gov.au/about-us/news-and-alerts/bushfires-and-scams-0>

Spyros, A., Koritsas, I., Papoutsis, A., Panagiotou, P., Chatzakou, D., Kavallieros D., Tsikrika, T., Vrochidis, S., & Kompatsiaris, I. (2025). AI-based holistic framework for cyber threat intelligence management. *IEEE Access*, 13, 20820–20846. <https://doi.org/10.1109/ACCESS.2025.3533084>

Tang, B., Wang, J., Qiu, H., Yu, J., Yu, Z., & Liu, S. (2022). Attack behavior extraction based on heterogeneous cyberthreat intelligence and graph convolutional networks. *Computers, Materials & Continua*, 74(1), 235–252. <https://doi.org/10.32604/cmc.2023.029135>

Vicari, R., & Komendatova, N. (2023). Systematic meta-analysis of research on AI tools to deal with misinformation on social media during natural and anthropogenic hazards and disasters. *Humanities and Social Sciences Communications*, 10(1), 332. <https://doi.org/10.1057/s41599-023-01838-0>